

SatsPath Threat Model

Disclaimer: This is hackathon software. Do not use with real funds.

Scope

This document covers threats against the SatsPath protocol prototype, focusing on the resolution, signing, and routing layers. It does not cover the underlying Bitcoin, Lightning, or Ark security models.

Threat Table

Threat	Risk	MVP Mitigation	Future Mitigation
Fake alias registration	Attacker registers <code>alice@bank.com</code> before Alice	First-come-first-served local registry; no domain verification	Domain-ownership proof via BIP-353 DNS TXT records; DKIM-signed registration challenges
Server/registry tampering	Registry file modified to replace Alice's pubkey with attacker's	All profiles are signed by the identity key; signature verified before payment	Decentralized registry (Nostr, DHT) with append-only semantics; client-side signature pinning
Key replacement attack	Attacker replaces <code>identity_pubkey</code> in a profile	Signature covers the entire profile including the pubkey; overwriting the key breaks the signature	Pinned pubkey in BIP-353 DNS record; certificate transparency for pubkey changes
Email takeover	Attacker takes over <code>alice@example.com</code> and re-registers	Registry does not verify email ownership at MVP	DKIM challenge during registration; WebAuthn-based domain binding
LNURL spoofing	Attacker serves a malicious LNURL endpoint	LNURL not verified at MVP; routing is simulated	TLS certificate pinning; LNURL-auth for identity binding; domain-bound LNURL endpoints
On-chain privacy leaks	Multiple payments to the same address reveal transaction graph	Multiple on-chain methods supported; different addresses per method	Silent Payments (BIP-352); hierarchical derivation so each payment gets a fresh address
Lost keys	User loses their <code>.satspath/keys.json</code>	Keys are local; demo only; no recovery mechanism at MVP	Nostr-based key backup (NIP-06); seed phrase with BIP-39; multi-sig recovery

Threat	Risk	MVP Mitigation	Future Mitigation
Malicious invite links	Attacker crafts an invite URL for a different alias/amount	Invite contains alias hash + amount; receiver should verify independently	Signed invites using sender's identity key; expiry timestamps; single-use tokens
Ark server trust assumptions	Ark server can censor or delay payments	MockArkClient at MVP; no real Ark integration	Covenants-based Ark with client-side verification; multi-server federation
Fee manipulation	Attacker serves a fake mempool.space response	Falls back to safe <code>hourFee=5</code> on API error	Multiple fee data sources; user-configurable fee source; local fee estimation
Replay attacks	Old payment request reused	<code>updated_at</code> timestamp in profile; profiles can be revoked by re-signing	Nonce in payment requests; short-lived payment intents with expiry
Profile downgrade	Attacker strips Lightning method to force on-chain	Profile is signed; removing methods breaks signature	Version-pinned profiles; minimum method count enforcement

Trust Model

TRUSTED:

- User's own keypair (generated locally, never transmitted)
- secp256k1 / ECDSA signature validity

PARTIALLY TRUSTED:

- Local registry (file system trust)
- mempool.space fee API (falls back to mock on failure)

NOT TRUSTED (at MVP):

- Email ownership
- Domain ownership
- Ark server
- LNURL endpoint content

Key Principles

1. **Receiver controls keys.** SatsPath never generates or stores keys on behalf of the receiver.
2. **Signatures are mandatory.** No payment should proceed against an unverified profile.
3. **Fail safe.** When in doubt, reject and show a clear error rather than proceeding.
4. **Privacy by default.** Multiple on-chain addresses; avoid address reuse.
5. **Invite rather than proxy.** For unknown users, create an invite that the receiver claims with their own keys.